



Projet Spécialisation Développement

Table des matières

A. Contexte	p. 1
B. Fonctionnalités	p. 1
C. Entité Produit	p. 2
D. URL de statistiques	p. 2
E. Contraintes associées au projet	p. 2
F. Modalités de rendu	p. 3

Contexte

Ce projet a pour but de mettre en application les différentes notions présentées pendant cette formation :

- Les fonctionnalités liées au paradigme de la programmation fonctionnelle
- Les possibilités offertes par JavaScript dans ses dernières versions : asynchronicité, éléments de syntaxe
- Les tests associés au code JavaScript
- Les bonnes pratiques de sécurité

Pour ce faire, une application "simple" sera réalisée. Elle sera l'occasion de mettre en application les différents éléments listés ci-dessus.

Fonctionnalités

Votre application possèdera les fonctionnalités suivantes :

- En tant que visiteur :
 - Se connecter
 - S'inscrire
 - Afficher tous les produits
 - Afficher un seul produit
 - Rechercher des produits
 - Ajouter un produit au panier
 - Accéder à l'URL de statistiques
- En tant que personne connectée :
 - Visualiser son dashboard (page vide)
 - Se déconnecter
 - Ajouter un produit
 - Modifier un produit
 - Supprimer un produit

Entité Produit

L'entité produit possède à minima les champs suivants :

- Identifiant
- Libellé
- Description
- Images (plusieurs)
- Prix
- Catégorie (cela peut être un simple texte)

URL de statistiques

Une URL devra mettre à disposition les catégories ainsi que le nombre de produits par catégorie, au format JSON.

Exemple de contenu attendu :

```
[  
  { "nom": "Alimentation", "compte": 35 },  
  { "nom": "Ameublement", "compte": 12 },  
  { "nom": "Sport", "compte": 23 }  
]
```

Il est important que cette URL soit accessible à l'ensemble des IP tentant d'accéder à cette ressource.

Contraintes associées au projet

Voici la liste des contraintes techniques à respecter :

- Le front doit avoir une URL particulière (ex: localhost:3000) et le back une autre URL (ex: localhost:5000).
- Prévalence du frontend : la majorité du code doit être réalisé en front. Le back n'est censé mettre à disposition que des APIs.
- Vous n'avez pas le droit à React ou à un framework front comme Angular ou Vue.
- Les bibliothèques de type "front" comme Bootstrap, tailwind qui ne permettent de faire que du visuel sont autorisées et même encouragées.
- Il faudra utiliser une base de données relationnelle. Vous pouvez utiliser MySQL, MariaDB, Postgre ou SQLite.

- Le code devra utiliser la programmation fonctionnelle et les bonnes pratiques associées à ce paradigme : peu de déclarations de variables, fonctions "pures", asynchrone, gestion des erreurs, expressions lambda.
- Au choix : utiliser Jest ou Mocha pour une deux deux entités : soit votre CRUD produit, soit l'authentification.
- Bonus : utiliser un bundler comme Webpack ou Vite.

Voici la liste des contraintes de sécurité à respecter :

- Respect des CORS : La totalité des APIs mises à disposition par le serveur (à l'exception de l'URL de statistiques) doit être limitée à localhost:3000.
- Protection CSRF : les formulaires, notamment de suppression, doit être vérifiés par CSRF.
- Les CSP doivent être validées sur le site <https://csp-evaluator.withgoogle.com/>. Aucun risque de sécurité potentiel ou avéré ne doit être présent.
- Le système de rapport CSP doit être fonctionnel : une page dédiée doit pouvoir afficher les dernières erreurs de CSP trouvées, uniquement quand on est connecté. Inspirez-vous de <https://csper.io/blog/csp-report-filtering>.
- L'upload d'images ne doit pas être un vecteur d'attaque.
- Le fichier security.txt doit être présent.

Voici la liste des bonnes pratiques OWASP à respecter :

- Toutes les pages doivent vérifier l'identité de la personne se connectant, pas juste le dashboard
- Les mots de passe doivent être hashés avec un algorithme de hash sécurisé (ex: bcrypt)
- Toutes les requêtes doivent être protégées des failles XSS
- Le mot de passe doit correspondre à une politique de sécurité stricte : <https://pages.nist.gov/800-63-4/sp800-63b.html#appA>

Attention

Il n'est pas nécessaire d'acheter ou de posséder un nom de domaine pour réaliser ce projet. Ne dépensez pas d'argent pour la réalisation de ce projet.

Si vous avez un nom de domaine, et bien qu'il n'y ait aucun point supplémentaire accordé si vous y arrivez, vous pouvez tenter d'obtenir la note A+ sur l'observatoire de Mozilla : <https://observatory.mozilla.org/>

Modalités de rendu

Le projet doit être réalisé par groupe de 2 à 4 personnes. La note sera portée sur les éléments suivants :

- Les fonctionnalités sont présentes
- Une documentation est présente pour l'installation du projet
- Les bonnes pratiques de développement sont respectées (qualité du code, commentaires)
- Des malus pourront être appliqués en cas de non-respect du nombre de personnes par groupe, de plagiat ou de rendu en retard.